

Construccion de monitoreo SOC

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha 18/02/26

Detención temprana de ransomware

Introducción

El monitoreo integral de eventos de red y de endpoints representa una práctica esencial dentro de los modelos actuales de detección y respuesta ante incidentes. En contraste con enfoques tradicionales que se centran únicamente en perímetros o dispositivos individuales, la clasificación en múltiples capas permite identificar patrones de ataque complejos que, si se consideran de manera aislada, podrían no ser detectados este método está en consonancia con los principios de defensa en profundidad que se promueven y con los marcos tácticos que han sido desarrollados.

Caso de monitoreo: Detección anticipada del despliegue de ransomware mediante clasificación híbrida

Descripción del escenario

El ransomware contemporáneo no solo se encarga de cifrar archivos, sino que también lleva a cabo actividades preliminares como el escalamiento de privilegios, la desactivación de defensas y la exploración de recursos compartidos en la red. Por lo tanto, su detección eficaz requiere una visibilidad completa tanto del comportamiento del host como del tráfico interno

y externo.

Eventos considerados

Eventos de Endpoint

Ejecución masiva de procesos con una alta tasa de modificación de archivos.

Eliminación de copias de seguridad mediante comandos administrativos.

Desactivación o alteraciones de servicios de seguridad locales.

Cambios rápidos en las extensiones de archivos dentro de directorios críticos.

Eventos de Red

Aumento inusual del tráfico SMB hacia múltiples recursos compartidos.

Conexiones simultáneas a varios servidores de archivos internos.

Transferencia lateral de ejecutables a través de protocolos administrativos.

Intentos de comunicación con direcciones IP externas que están asociadas a infraestructura de
pago o de mando y control.

Lógica de evaluación propuesta

La regla de monitoreo dentro del SIEM se estructura en tres fases que están temporalmente
correlacionadas

Indicador inicial en endpoint: detección de eliminación de copias sombra.

Actividad lateral en red: incremento anómalo de conexiones SMB desde el mismo host.

Comportamiento destructivo: modificación masiva de archivos en un intervalo de menos de 5 minutos.

Si se cumplen las tres condiciones dentro de una ventana de 15 minutos, el sistema eleva la alerta a un nivel crítico y activa un playbook automatizado para contención.

Fundamentación técnica

La integración de eventos disminuye el riesgo de falsos positivos que podrían resultar de actividades administrativas legítimas por ejemplo, la eliminación de copias de sombra puede ser una tarea válida; Sin embargo, su valoración con la propagación lateral y el cifrado masivo constituye un patrón inequívoco de amenaza.

Este enfoque responde a las recomendaciones de monitoreo continuo y gestión centralizada de registros, como lo describe el NIST, así como a las mejores prácticas de controles críticos.

Análisis de eventos dentro del SOC

Introducción

El Centro de Operaciones de Seguridad actúa como el núcleo operativo dentro de la ciberseguridad de una organización al reunir y analizar eventos provenientes de diversas fuentes tecnológicas en ambientes donde predominan amenazas sofisticadas, el monitoreo aislado de eventos de red o de terminal resulta inadecuado; por lo tanto, los marcos actuales aconsejan la evaluación de múltiples fuentes y el monitoreo constante como prácticas fundamentales además, la integración de eventos permite la identificación de comportamientos observables utilizando técnicas definidas.

Relación de eventos dentro del SOC

1. Nivel técnico

Los eventos procedentes de terminales se consolidan en plataformas de gestión de eventos e información de seguridad o detección y respuesta extendida la compensación a través de coincidencias tanto temporales como de activos facilita la conversión de alertas individuales en incidentes con contexto, lo que ayuda a minimizar falsos positivos y mejorar la precisión en la detección.

2. Nivel operativo

La integración de eventos potencia el ciclo de gestión de incidentes que incluye recogida, normalización, clasificación, priorización y respuesta este método mejora el trabajo en distintas etapas y optimiza métricas como el tiempo medio para la detección y respuesta.

3. Nivel estratégico

El análisis conjunto de eventos apoya la mejora continua del programa de ciberseguridad y refuerza los controles que se alinean con buenas prácticas internacionales.

Documentación de integración del SOC

Mi documento presentara de manera organizada la combinación de eventos de red y de endpoints en el Centro de Operaciones de Seguridad, con el propósito de mejorar la detección temprana de amenazas a través de una limitación de diversas fuentes, en conformidad con las mejores prácticas.

2. Ámbito

La integración se aplica a:

Estaciones de trabajo corporativas.

Servidores esenciales.

Dispositivos de seguridad tanto perimetrales como internos.

Esto incluye la recolección, normalización, clasificación y gestión de eventos asociados con amenazas tanto internas como externas.

3. Marco Regulatorio y de Referencia

La implementación se basa en:

Gestión centralizada de registros.

Modelo táctico de amenazas.

Controles de seguridad críticos.

4. Estructura de la Integración

Capa de Recolección

Agentes EDR distribuida en los endpoints.

Firewalls e IDS/IPS transmitiendo registros de manera segura a través de Syslog.

Controladores de dominio generan eventos de autenticación.

Capa de Normalización

Conversión de registros a formato estructurado.

Unificación de campos.

Capa de Enriquecimiento

Consulta de reputación de direcciones IP.

Clasificación según la criticidad de los activos.

Vinculación con técnicas del marco ATT&CK.

Capa de Correlación

Reglas basadas en intervalos de tiempo.

Coincidencia por usuario/host/dirección IP.

Asignación de evaluación de riesgo.

Capa de Respuesta

Generación automática de incidentes.

Activación de manuales de procedimientos.

Aislamiento de hosts comprometidos.

5. Casos de Uso Implementados

Movimiento Lateral

Endpoint: autenticación privilegiada inusual.

Rojo: Múltiples conexiones internas SMB.

Resultado: alerta crítica y escalamiento a Nivel 2.

Exfiltración de Datos

Endpoint: compresión masiva de archivos sensibles.

Rojo: incremento inusual del tráfico saliente cifrado.

Resultado: bloqueo preventivo de conexión externa.

Actividad Tipo Ransomware

Endpoint: eliminación de copias de sombra.

Rojo: rápida propagación lateral.

Resultado: aislamiento automático del dispositivo afectado.

Métricas de Desempeño

Tras la implementación, se observaron:

Reducción de falsos positivos.

Disminución del Tiempo Promedio de Detección.

Mejora en el Tiempo Promedio de Respuesta.

Mayor priorización basada en niveles de riesgo.

Control y Mejora Continua

Revisión trimestral de las reglas de evaluación.

Actualización de los indicadores de compromiso.

Validación periódica de la cobertura ATT&CK.

Ajuste de manuales de procedimientos conforme a las lecciones aprendidas.

Conclusión

La integración organizada de eventos de red y de endpoints ha fortalecido la capacidad analítica y operativa del SOC, permitiendo la transformación de eventos aislados en incidentes contextualizados, mejorando la detección y respuesta ante amenazas avanzadas y contribuyendo al desarrollo del programa de ciberseguridad de la institución.

Referencias

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management (NIST Special Publication 800-92)*. National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

MITRE Corporation. (2024). *MITRE ATT&CK®: Design and philosophy*.

https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy.pdf

Wang, Z., Kumar, S., & Lee, W. (2020). Correlated event detection in security monitoring. *IEEE Transactions on Information Forensics and Security*, 15, 2040–2053.

<https://doi.org/10.1109/TIFS.2019.2952927>

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide (NIST Special Publication 800-61 Rev. 2)*. National Institute of

Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>